Private Access (ZPA)

About Policies

Users cannot access any internal applications you've configured for Private Access (ZPA), regardless of whether you explicitly define your applications or enable application discovery, until you configure policies for them. You can configure the following policy types: access policies, client forwarding policies, isolation policies, and timeout policies. If you are using the Log Streaming Service (LSS), you can also configure log streaming policies for information captured by a log receiver. To learn more, see Configuring a Log Receiver.

Private Access uses the Name Identifier (NameID) within a SAML assertion for IdP configuration and authentication. Using NameID as a SAML attribute within access and timeout policy rules is not supported.

However, you can use the value associated with NameID within your policy rule criteria by explicitly defining a user attribute (e.g., Email Address, User Name, etc.). In your IdP's SAML assertion, the user attribute can use the same value, and then you can include this attribute in your policy rule criteria.

See example SAML JSON

```
{
"nameid": "jane.doe@example.com"
"orgid": "86753098675309696"
"saml_attributes": {
    "Group": "ZPA-users",
    "First Name": "Jane",
    "Last Name": "Doe",
    "Email Address": "jane.doe@example.com"
   }
}
```

Private Access allows you to apply the following policies to your organization:

- Access Policy: Access policy rules enable you to implement role-based access control. This allows you to define rules that determine who has access to an application. To learn more, see About

©2026 Zscaler, Inc. All rights reserved.

Access Policy. To view examples of how an organization can configure access policy rules for a variety of scenarios, see Access Policy Configuration Examples.

- AppProtection Policy: AppProtection policy rules allow you to create rules that define when application requests need to go through an AppProtection control. To learn more, see About AppProtection Policy.
- Browser Protection Policy: Browser Protection policy rules allow you to create rules that define Browser Protection requests for Browser Protection profiles. To learn more, see About Browser Protection Policy.
- Client Forwarding Policy: Client forwarding policy rules allow you to create rules that define when application requests are forwarded to Private Access from the Zscaler Client Connector. To learn more, see About Client Forwarding Policy.
- Isolation Policy: Isolation policy rules allow you to create rules that define what isolation profiles to use or bypass. To learn more, see About Isolation Policy.
- Privileged Remote Access (PRA) policies: Privileged Remote Access (PRA) policies consist of privileged credentials policies and privileged capabilities policies. Privileged credentials policy rules allow you to assign privileged consoles to include designated credentials. To learn more, see About Privileged Credentials Policy. Privileged capabilities policy rules allow you to set permissions for File Transfer, Clipboard, and Session Recording features. To learn more, see About Privileged Capabilities Policy.
- Timeout Policy: Timeout policy rules allow you to create granular rules that control authentication timeout and idle connection timeout settings. To learn more, see About Timeout Policy.
- Redirection Policy: Redirection policy rules allow you to set criteria for preferring Private Service Edges for Private Access over Public Service Edges for Private Access. To learn more, see About Redirection Policy.

Policy Evaluation Order

Private Access evaluates policy rules using the most specific application segment and a top-down, first-match principle. For example, when a user requests a specific application, Private Access starts evaluating all of your configured policies, starting with the first rule in a set of policy rules. As soon as it finds a policy that matches the criteria that was specified in a rule, it enforces that policy rule and disregards all other rules that follow, including any potentially conflicting rules.

Private Access evaluates policy rules in the following order:

1. When the application request is received, Private Access first tries to identify the rule that matches the criteria. If application segments are part of the criteria, then Private Access chooses the rule corresponding to the most specific application segment for a given domain name or IP address.

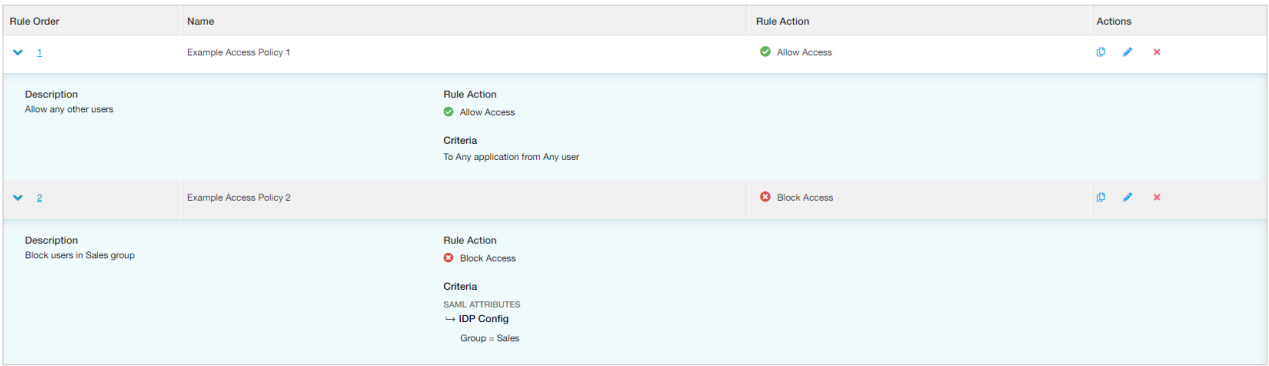
©2026 Zscaler, Inc. All rights reserved.

2. Private Access evaluates your policy rules and executes the specified action for the rule. Within a set of policy rules, if none of the policy rules apply then the following applies:
    - For access policy, access to the application is implicitly set to Block Access. This is also the case if you do not define any policy rules at all within the Zscaler Admin Console. To learn more, see About Access Policy.
    - For timeout policy, Private Access applies the default timeout policy rule. To learn more, see About Timeout Policy.
    - For client forwarding policy, access to the application is implicitly set to Forward to Private Access. This is also the case if you do not define any policy rules at all within the Zscaler Admin Console. To learn more, see About Client Forwarding Policy.
    - For isolation policy, Private Access applies the default isolation policy rule. To learn more, see About Isolation Policy.

These policy evaluation order guidelines apply in the following scenarios:

Conflicting Access Policy Rules

- An organization configures an access policy rule that allows access to any application for any user.
- It temporarily wants to block the "Sales" group from accessing any applications, so it configures an additional access policy rule denying them access.

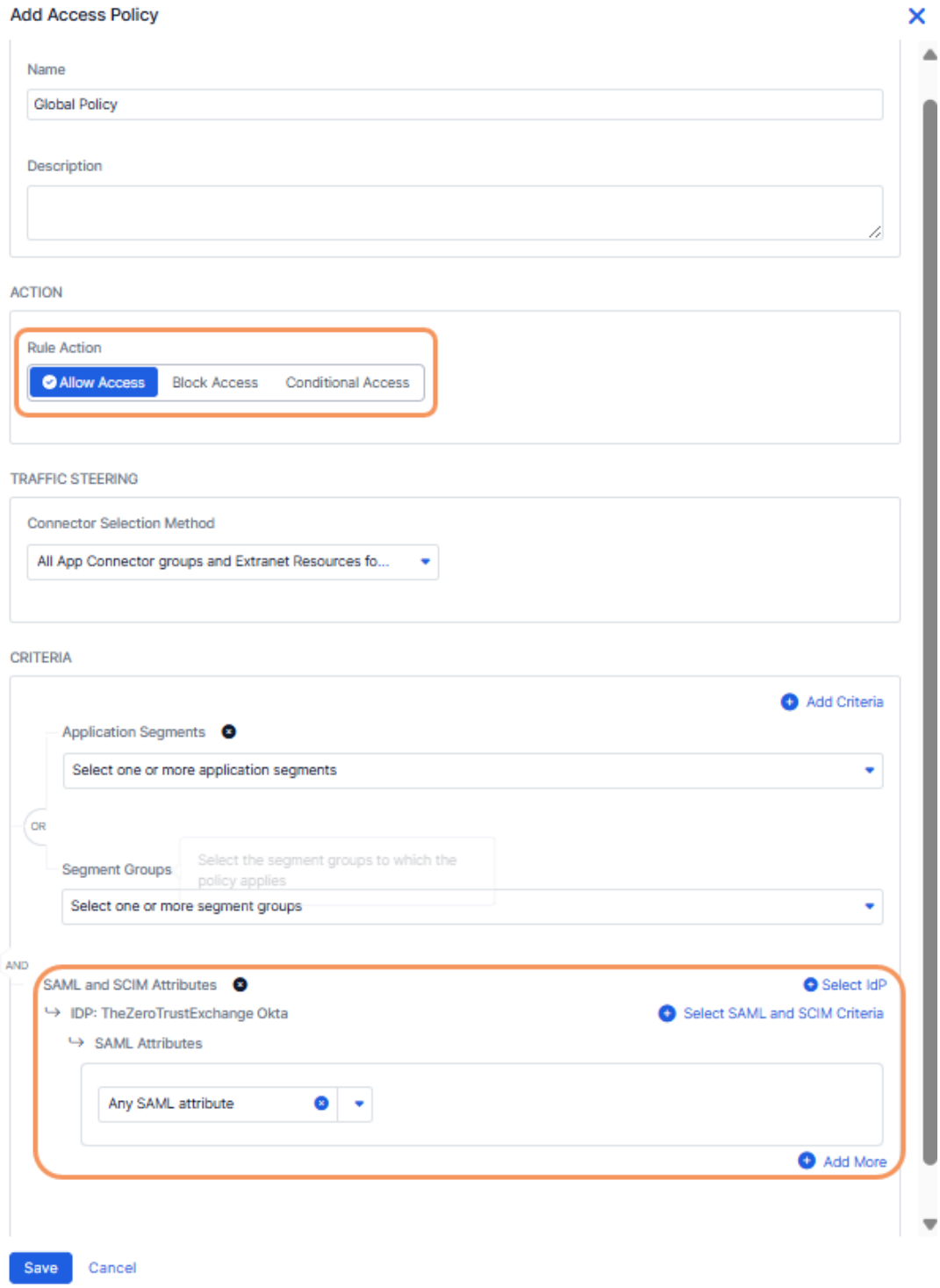


In this scenario, users in the "Sales" group are not blocked from accessing any applications because these users match the first policy rule, which allows any users access to any applications. Private Access applies that first access policy rule and disregards the second policy rule. To resolve this issue, the order of the access policy rules must be modified so that the policy rule blocking the "Sales" group comes before the policy rule allowing any users access to any applications.

©2026 Zscaler, Inc. All rights reserved.

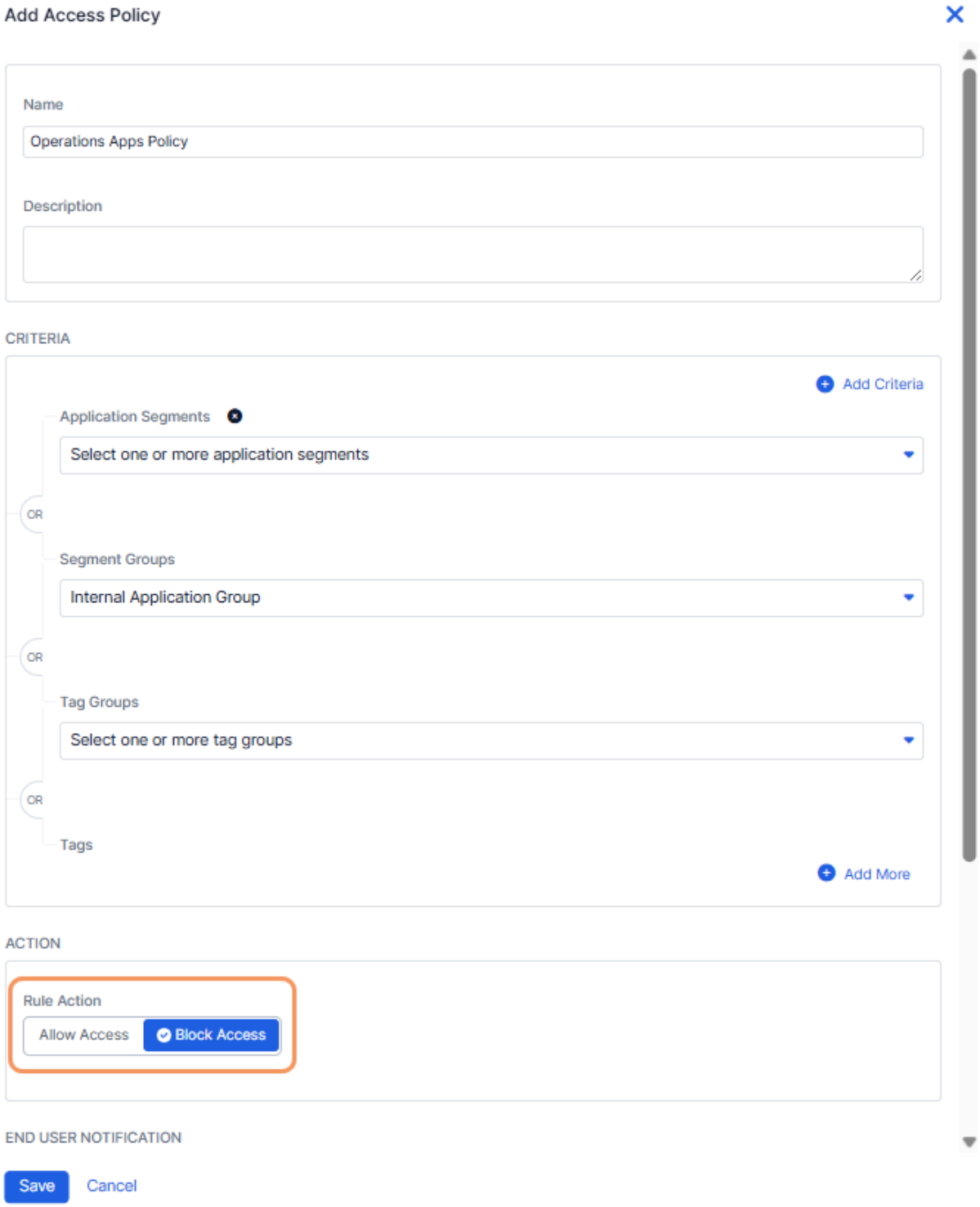
Conflicting Access Policy Rules with Segment Groups

- An organization configures an access policy rule that allows all applications for the "Marketing Dept."



©2026 Zscaler, Inc. All rights reserved.

- The organization also configures a policy that denies the "Operations Apps" segment group to the "Marketing Dept."



©2026 Zscaler, Inc. All rights reserved.

In this scenario, even if the organization configured the latter policy denying the "Operations App" segment group to the "Marketing Dept," users from "Marketing Dept" still have access to the "Operations Apps" segment group. When a user from the "Marketing Dept" requests an application from the "Operations App" segment group, Private Access first checks the access policy rules and finds the policy rule allowing Marketing users access to any application. It then applies that access policy rule and immediately stops checking any other policies, because a matching policy was found for the user.

©2026 Zscaler, Inc. All rights reserved.